

**Engineering – Management and Information Systems**

**Introduction to Cybersecurity**

## **Lab 3 – Solution Guide**

### **Incident Response & Log Forensics (HELIX Systems)**

**INSTRUCTOR ONLY — DO NOT DISTRIBUTE**

|                   |                                                          |
|-------------------|----------------------------------------------------------|
| <b>Techniques</b> | Brute force, sudo privesc, persistence, lateral movement |
| <b>MITRE</b>      | TA0001, TA0004, TA0003, TA0008, TA0010                   |
| <b>Max points</b> | 20                                                       |

## Task 1 — Initial Access on helix-web (3 points)

**Attacker IP:** 185.220.101.47

**Targeted user:** devops

**Successful login time:** 03:17:42

**Key log lines:**

```
Apr 24 03:05:03 helix-web sshd[1201]: Failed password for devops
    from 185.220.101.47 port 42001 ssh2
... (25 total failures)
Apr 24 03:17:42 helix-web sshd[1231]: Accepted password for devops
    from 185.220.101.47 port 43100 ssh2
```

**Commands expected from the student:**

```
grep "Failed_password\|Accepted_password" /var/log/auth.log
grep 'Failed_password_for_devops' /var/log/auth.log | wc -l
# 25
```

## Task 2 — Privilege Escalation (4 points)

**Command used:** `sudo /usr/bin/find`

**Misconfiguration:** `/etc/sudoers.d/devops` contains `NOPASSWD: /usr/bin/find`

**MITRE technique:** T1548.003 — Abuse Elevation Control Mechanism: Sudo and Sudo Caching

**Prevention:** Remove `NOPASSWD`; apply principle of least privilege; use `visudo`

**Key log lines:**

```
Apr 24 03:18:01 helix-web sudo: devops : TTY=pts/0 ;
    PWD=/home/devops ; USER=root ; COMMAND=/usr/bin/find
```

```
# /etc/sudoers.d/devops
devops ALL=(ALL) NOPASSWD: /usr/bin/find
```

**GTFOBins vector:** `find`'s `-exec` flag executes arbitrary commands as root.

```
sudo find / -name "*.conf" -exec cat {} \;
```

## Task 3 — Persistence & Post-Exploitation (3 points)

**Backdoor account:** `maint` (UID 1003)

**Privileges:** `NOPASSWD: ALL` via `/etc/sudoers.d/maint`

**Key log lines:**



- **Backdoor:** `maint` account (UID 1003, NOPASSWD: ALL)
- **Files:** `/opt/helix/data/clients.db`, `.exfil_marker`
- **Technique:** `GTFOBins sudo find (T1548.003)`

### Complete attack timeline

| Time        | Host      | Event                                                                  |
|-------------|-----------|------------------------------------------------------------------------|
| 03:05–03:16 | helix-web | 25 failed SSH attempts for devops from 185.220.101.47                  |
| 03:17       | helix-web | Successful login as devops                                             |
| 03:18       | helix-web | Privilege escalation via <code>sudo find</code>                        |
| 03:19       | helix-web | Backdoor account <code>maint</code> created                            |
| 03:21       | helix-db  | Lateral movement from 192.168.50.10                                    |
| 03:22       | helix-db  | Access to <code>clients.db</code> + <code>.exfil_marker</code> created |

### Recommended remediation

1. Disable `devops` and `maint` accounts immediately
2. Remove NOPASSWD from `/etc/sudoers.d/devops`
3. Rotate all credentials on both servers
4. Implement SSH key-based auth; disable password authentication
5. Deploy `fail2ban` + `auditd` on all servers
6. Apply least-privilege ownership on `/opt/helix/data/`